Course Code: ITA1439 Course Name: Ethical Hacking

Slot: A

CO2 – ASSIGNMENT 2

Item	Details
Nature of Assignment	**Individual**
Duration	**1 Week**
Total Marks	**50**
Student Name	**K.Dhanush Reddy**
Register Number	**192324087**

Course Outcome (CO2)

Execute footprinting and social-engineering techniques such as DNS analysis, competitive intelligence gathering and attack simulations to collect information for identifying potential security risks.

Submission note: Examples, test targets, commands and outputs in this report are educational. Any output marked simulated/lab-generated is illustrative and must not be represented as a live result. Replace it with genuine evidence from an authorized lab if your instructor requires execution evidence.

Table of Contents

- Scenario and Assessment Design Philosophy
- Ethics and Authorization Statement
- Lab Environment and Tools
- Q1 – Evaluate and Engineer a Footprinting Strategy
- Q2 – Build a Reliable DNS Footprinting Workflow
- Q3 – Create a Competitive-Intelligence Awareness Utility
- Q4 – Design a Reconnaissance Data-Validation Mechanism
- Q5 – Evaluate Footprinting of a Hierarchical Organization
- Q6 – Evaluate Footprinting Approaches Under Constraints
- Q7 – Integrated Review: Diagnose, Redesign and Defend

Evaluation and Engineering of Footprinting, Reconnaissance and Social-Engineering-Awareness Workflows in an Authorized Assessment

SECTION 0 – SCENARIO AND ASSESSMENT DESIGN PHILOSOPHY

This assignment is intended for cybersecurity students who must evaluate the quality of reconnaissance and information-gathering decisions, not merely run tools. The analyst must plan a strategy, predict what may be discovered, design difficult test cases, collect evidence from authorized targets, identify limitations, compare alternatives and defend engineering decisions.

All work must remain within written authorization and the agreed scope. Use reserved example domains, a personally owned test domain, a local lab DNS server, or an intentionally provided training target such as zonetransfer.me only in accordance with its published testing conditions and course instructions. Do not launch attacks against live systems or real people. Do not collect or publish personal information.

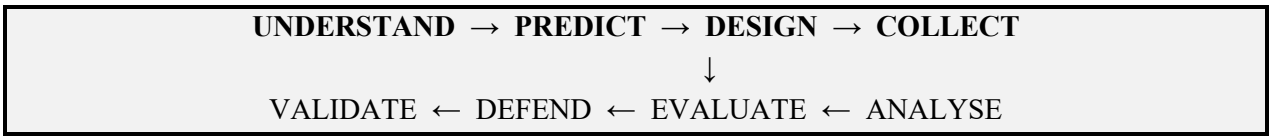


Figure 1: Assessment flow

Ethics and Authorization Statement

Before collecting information, confirm written permission, target ownership, allowed techniques, time window, rate limits, data-handling requirements and stop conditions. Passive public-source research can still create privacy and contractual concerns. Active DNS queries and zone-transfer attempts must be limited to explicitly authorized systems. If scope is uncertain, stop and request clarification.

Lab Environment and Tools

Table 2: Tools and intended use

Tool / source	Purpose	Safety / evidence note
whois	Review public domain-registration information where available.	Record query date; privacy services and registry policies may hide details.
nslookup	Query DNS records using a simple command-line interface.	Use only an in-scope domain or local lab.
dig	Inspect A, MX, NS, TXT and other DNS records; request AXFR only when explicitly allowed.	Save the exact command and output.
Search operators	Search public pages using site:, filetype: and intitle:.	Do not use results to target real individuals.
Wayback Machine / archived pages	Review historical public pages and changed technology references.	Older content may be stale or removed for a reason.
Python / Bash scripts	Automate repeatable, scope-checked processing.	Add rate limits, logging and an allow-list.
Local BIND DNS lab	Create controlled DNS cases, including stale data and AXFR policy.	Preferred for repeatable experiments and safe negative tests.

Evidence and result labelling

Table 3: Evidence labels

Label	Meaning	Handling rule
VERIFIED-IN-SCOPE	Confirmed result from an authorized target and reliable source.	May be included in the assessment report.
UNVERIFIED	Result is incomplete, contradictory or not confirmed.	Do not use as a fact; re-query or corroborate.
OUT-OF-SCOPE	Target or service is not explicitly included in authorization.	Do not query further; quarantine or remove from workflow.
PERSONAL-DATA	Information that identifies or exposes a real individual.	Avoid collection; redact and securely delete if encountered.
SIMULATED / LAB-GENERATED	Illustrative output created for this report rather than a live query.	Clearly label; replace with lab evidence if execution is required.

Q1 – Evaluate and Engineer a Footprinting Strategy

1.1 Problem Context

A security team has authorization to footprint a test organization before a penetration test. A single source is insufficient: registration data may be privacy-protected, DNS may expose infrastructure, and public documents may reveal technology or organizational information. The strategy must combine sources, verify reliability and keep out-of-scope information separate.

1.2 Strategy design: passive and active techniques

Start with passive sources to build a low-impact baseline. Use active DNS queries only for approved domains. Record the source, timestamp, command, result, confidence and scope status for every item. Corroborate important facts using at least two independent sources when practical.

Table 4: Footprinting techniques and expected outputs

Technique	Tool / command	Type	Expected output
Registration lookup	whois example.com	Passive	Registrar, dates, nameservers where disclosed.
DNS lookup	dig example.com A; nslookup example.com	Active query to DNS	A/AAAA answer and resolver response.
Mail DNS	dig example.com MX	Active query to DNS	Mail exchanger records and priorities.
Public web search	site:example.com filetype:pdf	Passive	Indexed public documents and pages.
Title search	site:example.com intitle:careers	Passive	Public careers and technology clues.
Archived pages	Search archived snapshots of the authorized domain	Passive	Historical pages; may be outdated.

1.3 Source-organized collection record

The following is an illustrative sample for a reserved example domain, not a live collection. In a real lab, paste the exact command output and date.

Table 5: Sample collection ledger

Source	Query / evidence	Finding (illustrative)	Status
WHOIS	whois example.com	Registrar fields are limited; registrant details may be privacy-protected.	VERIFIED-IN-SCOPE
DNS A	dig example.com A	An A answer is returned by the resolver; exact address may change.	VERIFIED-IN-SCOPE; timestamp required
DNS MX	dig example.com MX	Mail exchanger answer or no answer depending on domain configuration.	UNVERIFIED until run
Search engine	site:example.com filetype:pdf	May return indexed documents or no relevant files.	UNVERIFIED until checked
Third-party link	Link points to an unrelated provider domain.	Ownership and scope not established.	OUT-OF-SCOPE until approved

1.4 Four contrasting targets: prediction versus observation

Use fictional lab profiles so that the comparison can be repeated safely. The observation column below is a simulated baseline; replace it with the observed output from the instructor-approved lab.

Table 6: Prediction-versus-observation for four target profiles

Target profile	Prediction before collection	Simulated observation	Evaluation

A. Well-protected	Minimal public metadata; consistent DNS; few indexed documents.	WHOIS privacy is enabled; DNS answers are consistent; limited public documents.	Prediction broadly matches; absence of evidence is not proof of no exposure.
B. Information-leaking	Public documents may reveal staff roles, software names or internal naming conventions.	A fictional PDF lists a platform and generic department contacts.	Document metadata and job details need review; avoid personal-data collection.
C. Misconfigured DNS	Unexpected records, stale entries or overly broad disclosure may appear.	A lab zone contains an obsolete subdomain record and inconsistent TTLs.	Confirm with authoritative source; stale data can mislead.
D. Minimal public footprint	Few indexed pages and little registration detail.	Search results are sparse; DNS reveals only the expected records.	Use multiple sources; do not infer that the organization has no infrastructure.

1.5 Contradictions and source reliability

Table 7: Reliability review

Source	Illustrative reliability	Possible contradiction / limitation	How to handle
Authoritative DNS response	High for current DNS answer	Resolver cache or split-horizon setup may show a different view.	Record resolver, timestamp and TTL; compare authorized vantage points.
WHOIS / registry	Medium to high for registry fields	Privacy service or stale cached data can obscure ownership.	Cross-check official organization information; do not guess hidden details.
Search-engine result	Medium	Index may be old, incomplete or snippet-only.	Open the source page and record date.
Archived page	Medium for historical state	It describes a past state, not necessarily current systems.	Label historical; never treat as current without confirmation.
Unattributed online post	Low	Could be inaccurate, fabricated or unrelated.	Mark UNVERIFIED and exclude from conclusions.

1.6 Changed condition: one domain grows to 50 subdomains and third-party services

The original manual strategy is useful for a small target but becomes slow and inconsistent at scale. The revised process should use a written allow-list, batching, caching of previously validated results, gentle rate limits, duplicate detection and a mandatory scope check before any active query. Third-party services must be treated as out of scope unless written authorization explicitly includes them.

Table 8: Before-and-after strategy at scale

Dimension	Original manual method	Revised method	Trade-off
Scope control	Analyst checks each target manually.	Machine-readable allow-list and pre-query scope gate.	Requires initial list maintenance.
Collection	Commands entered one by one.	Batch passive lookups; bounded parallelism for approved queries.	Automation can amplify a bad input if scope gate fails.
Evidence	Notes in free-form text.	Structured CSV/JSON ledger with timestamp and source.	More setup, better auditability.
Duplicates	Manual spotting.	Normalize hostnames and deduplicate before querying.	Normalization rules need testing.
Rate and impact	Inconsistent delays.	Configured request limits, retries and stop condition.	May take longer but lowers operational risk.
Third-party assets	May be followed accidentally.	Default deny; add only after written approval.	Some useful links will be excluded until approved.

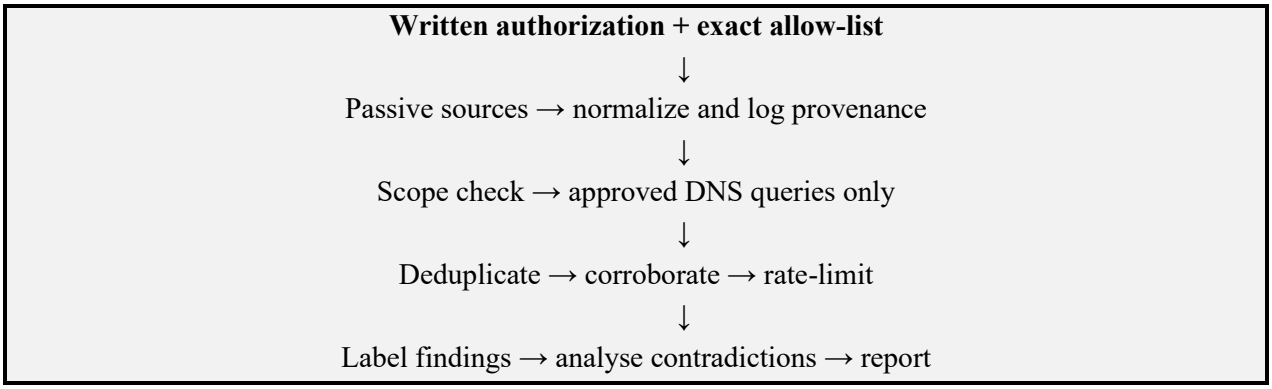


Figure 2: Final footprinting strategy

Real-Time Example: Security search services such as Shodan and Censys can help defenders discover internet-facing assets. Public documents can also contain metadata or technology clues. Discovery should be performed only within an authorized defensive assessment; search results are leads, not proof that a system is vulnerable.

Evidence Produced: A documented multi-source strategy, source-organized collection ledger, four target profiles, prediction-versus-observation analysis, reliability review and a scale-up redesign.

Q2 – Build a Reliable DNS Footprinting Workflow

2.1 Problem Context

DNS answers can differ because of split-horizon DNS, delegation, caching, stale records or misconfiguration. The workflow retrieves A, MX, NS and TXT records and attempts a zone transfer only when the target DNS server and the test window are explicitly authorized.

2.2 DNS workflow with authorization checkpoint

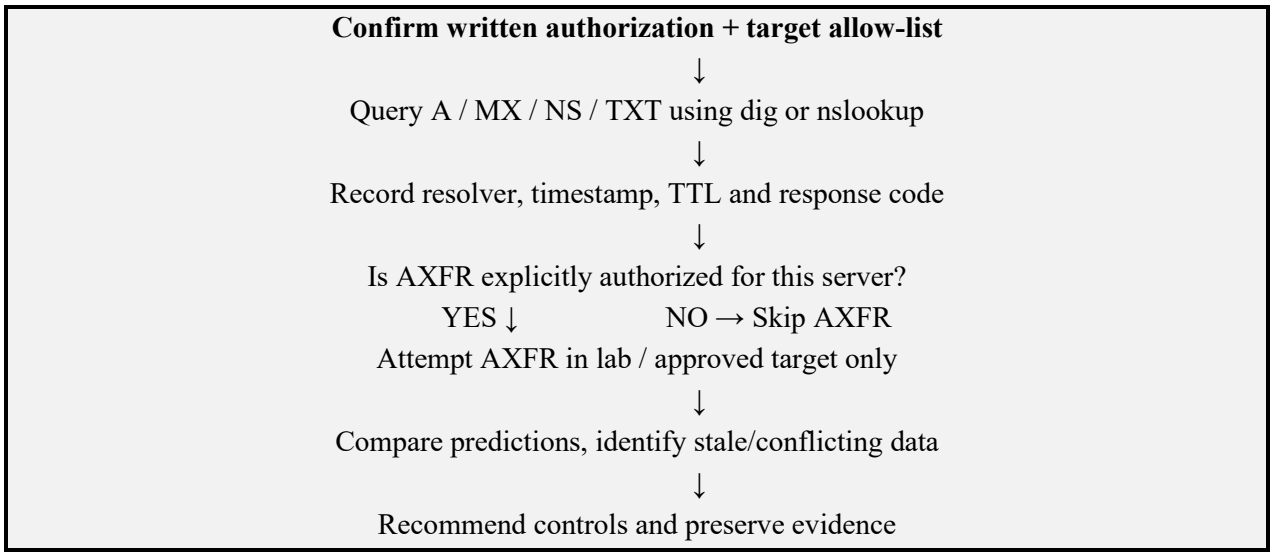


Figure 3: Authorized DNS workflow

2.3 Commands and interpretation

Command set (replace example.com only with an approved lab domain)

```
dig example.com A
dig example.com MX
dig example.com NS
dig example.com TXT
nslookup -type=A example.com
nslookup -type=MX example.com
# Only if written authorization explicitly permits it:
dig @ns1.lab.example AXFR lab.example
```

Sample query interpretation: an A record maps a name to an IPv4 address; MX identifies mail exchangers; NS identifies authoritative name servers; TXT can contain SPF, verification strings or other text. An AXFR response is a full zone transfer. A refused or timed-out transfer does not prove that the zone is otherwise secure.

2.4 Six contrasting DNS cases

Table 9: DNS test cases and prediction-versus-observation

Case	Prediction	Command / trace	Simulated observation	Evaluation
1. Secured authoritative server	A/MX/NS/TXT return expected records; AXFR refused.	dig lab.example A; ...; AXFR only if authorized	Expected records answer; AXFR returns REFUSED.	Good baseline; document response code.
2. AXFR allowed in isolated lab	Transfer may disclose all zone names and records.	dig @ns1.lab.example AXFR lab.example	Lab server returns several zone records.	Misconfiguration increases asset visibility; restrict it.

3. Stale record	Old host may still resolve or have expired service.	dig old.lab.example A	Answer appears with old TTL / obsolete address in simulated dataset.	Confirm owner and current service state; do not scan blindly.
4. Split-horizon DNS	Internal and external resolvers may differ.	dig @approved-external-resolver app.lab.example A	External view returns public address; internal view differs in lab.	Compare only authorized resolver vantage points.
5. Third-party delegation	NS points to an external DNS provider.	dig lab.example NS; dig service.lab.example NS	Subdomain delegates to provider.	Provider is not automatically in scope.
6. Missing mail-policy TXT	SPF/DMARC policy may be absent or incomplete.	dig lab.example TXT; dig _dmarc.lab.example TXT	No DMARC TXT answer in simulated test zone.	Potential email-spoofing risk; verify with mail administrator.

2.5 Zone-transfer risk evaluation

Table 10: Risk from an improperly permitted AXFR

Exposed item	Potential impact	Likelihood if AXFR is open to untrusted hosts	Recommended control
Hostnames and subdomains	Reveals asset naming and service map.	Medium to high, depending on zone content.	Restrict transfers to approved secondary servers.
Internal-looking labels	May reveal architecture or department naming.	Variable; labels alone do not prove reachability.	Avoid sensitive names; validate exposure.
Mail and service records	Can help an assessor understand dependencies.	Medium.	Review records and minimize unnecessary disclosure.
Stale or abandoned names	May reveal abandoned third-party services.	Variable; can increase takeover risk if misconfigured.	Remove stale records and verify provider ownership.

2.6 Countermeasure redesign

Use an access-control list (ACL) or allow-transfer policy so only approved secondary DNS servers can transfer a zone. TSIG can authenticate transfer requests between trusted servers. Test both a permitted secondary and an unapproved client in an isolated lab. Re-test after changes.

Table 11: Before-and-after exposure

Condition	Expected result	Security interpretation
Before: AXFR open to arbitrary clients in lab	Complete zone contents returned to any querying client.	Excessive disclosure; finding should be documented and corrected.
After: allow-transfer restricted + TSIG where supported	Approved secondary can transfer; unapproved client is refused.	Reduced exposure; verify legitimate replication still works.

Real-Time Example: The 2016 Dyn DNS incident demonstrated how disruption involving DNS infrastructure can affect many online services. It was a large DDoS event, not a zone-transfer incident. Separately, zonetransfer.me is a commonly used DNS zone-transfer practice target; follow its current instructions and course authorization before testing.

Evidence Produced: A DNS query workflow with an authorization checkpoint, six contrasting cases, record interpretation, zone-transfer risk analysis and a countermeasure redesign.

Q3 – Create a Competitive-Intelligence Awareness Utility

3.1 Problem Context

A repeatable workflow gathers public business information from job advertisements, annual reports, press releases and public organizational profiles. The purpose is to identify information that could make people more vulnerable to phishing, vishing, pretexting or tailgating, then recommend awareness controls. No social-engineering attack is performed against real people.

3.2 Public-source collection and provenance

Table 12: Search operators and purpose

Operator / source	Example query pattern	Purpose	Provenance to record
site:	site:fictional.example careers	Limit results to an authorized fictional organization domain.	Query, URL, access date, title.
filetype:	site:fictional.example filetype:pdf	Find public PDFs such as annual reports.	URL, document date, metadata checked.
intitle:	site:fictional.example intitle:press	Find pages with relevant titles.	Query, result title, URL, date.
Job advertisements	Search official careers page or public job board.	Identify broad technology-stack clues.	Publisher, URL, posting date, collection date.
Annual reports	Official investor / annual-report page.	Understand business units and public contact channels.	Report name, year, page.
Press releases	Official newsroom.	Identify public projects and supplier announcements.	Release date, URL, source organization.
Public profiles	Official company page or public role profile; avoid personal dossiers.	Understand role-level communication patterns.	Public URL, role-level item only; no personal data.

3.3 Item-to-technique mapping

Table 13: Public item, human risk and indicator

Collected item (fictional)	Possible technique	Indicator the recipient should notice	Countermeasure
Job ad mentions cloud platform and ticketing software	Phishing / pretexting	Message uses plausible technology vocabulary but unexpected link or urgency.	Verify through known help-desk channel; report suspicious links.
Press release names a new supplier	Pretexting / vishing	Caller claims to be supplier and asks for credentials or payment changes.	Call back using independently verified number.
Annual report lists generic office contact route	Vishing	Caller pressures staff to bypass normal identity checks.	Use standard verification questions and escalation.
Public visitor instructions mention reception location	Tailgating	Unknown person asks to follow an employee through a secure door.	Do not hold secure doors; enforce visitor badge and escort rules.

3.4 Fictional test organizations and predicted versus observed results

Table 14: Test organizations

Organization profile	Predicted information / risk	Simulated observation	Human-risk rating
Rich: Northstar Campus Services (fictional)	Many job ads, detailed reports and releases; more context available to impersonators.	Technology terms, department names and supplier references found across public pages.	Medium–High; information is rich but not itself an exploit.
Sparse: Cedarline Learning Lab (fictional)	Few pages; limited organizational details.	One generic contact page and a short careers page.	Low–Medium; fewer clues, but verification controls still matter.

Misleading: Blue Lantern Systems (fictional)	Conflicting pages and outdated technology references may confuse analysts.	Old press release conflicts with current job ad; current state cannot be assumed.	Medium; false or stale clues can support inaccurate pretexts.

3.5 Risk scoring

Use a simple qualitative score: likelihood (1–3) × impact (1–3). This is a prioritization aid, not a measured probability. Score only the information exposure and potential human consequence; do not rank real people.

Table 15: Illustrative human-risk scoring

Source / item	Likelihood	Impact	Score	Reason
Detailed job ad with technology stack	2	2	4 – Medium	Could make a fake IT message sound plausible.
Public supplier announcement	2	3	6 – High	Could support a supplier-impersonation story; payment changes need strong verification.
Generic office contact page	1	2	2 – Low	Provides a legitimate contact path but little sensitive detail.
Outdated archived release	2	1	2 – Low	May mislead an analyst; age must be visible in the report.

3.6 Modular architecture and new countermeasures

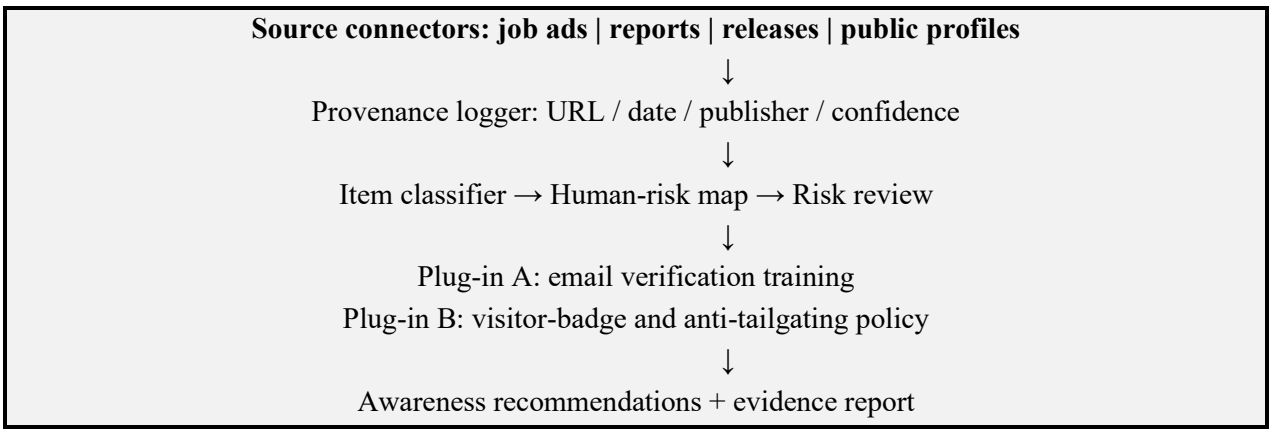


Figure 4: Modular competitive-intelligence awareness utility

Two added countermeasures: (1) require independent call-back verification for payment, password-reset and supplier-bank-detail changes; (2) apply a visitor-badge and escort process for controlled areas. These modules can be added without redesigning the source-collection pipeline.

Real-Time Example: Publicly reported incidents, including the 2020 Twitter incident involving social engineering and the 2023 MGM Resorts incident involving help-desk social engineering, show that human verification procedures matter. Job advertisements can also reveal technology vocabulary. This report uses those incidents only as awareness examples and does not reproduce attack instructions.

Evidence Produced: A provenance-based source workflow, search-operator table, fictional organization profiles, item-to-technique mapping, qualitative risk scoring and modular countermeasure design. No real person was targeted.

Q4 – Design a Reconnaissance Data-Validation Mechanism

4.1 Problem Context

Collected reconnaissance items may be out of scope, stale, duplicated, unverifiable or from a weak source. Each item must be checked before it influences the final assessment. The safest and most efficient design rejects out-of-scope material early, then checks freshness, duplication and reliability.

4.2 Validation pipeline

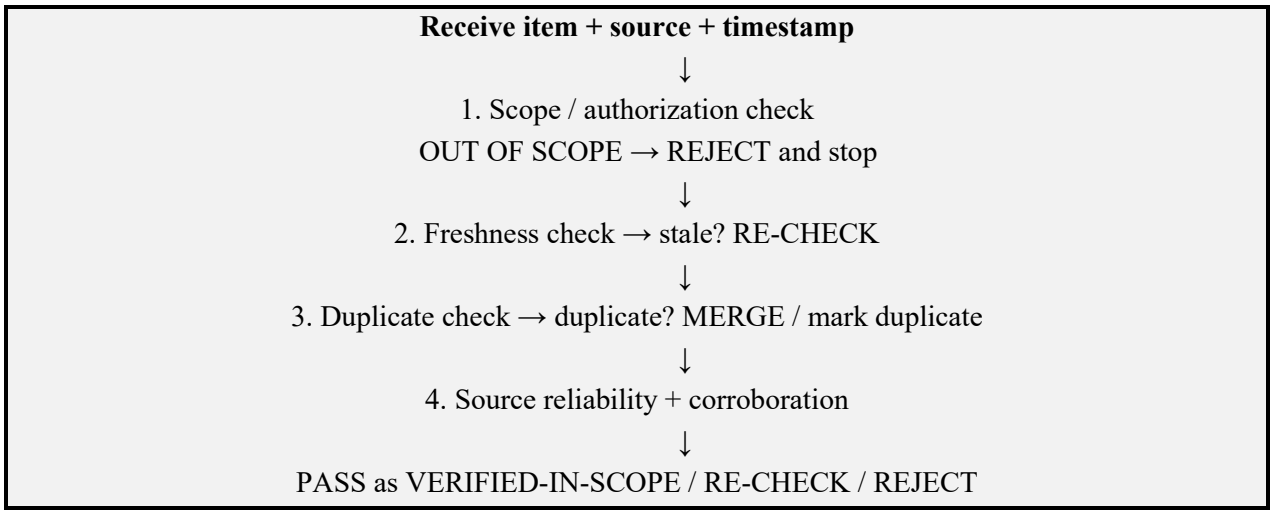


Figure 5: Validation pipeline

4.3 Decision rules and pseudocode

Table 16: Validation decisions

Condition	Decision	Reason
Target is not on the approved allow-list	Reject immediately	Prevents scope violation and avoids unnecessary processing.
In scope but stale	Re-check / recover	A new query or authoritative confirmation may resolve it.
Duplicate of a previously validated item	Merge or mark duplicate	Preserves traceability without counting it twice.
Source is weak or result cannot be verified	Re-check; reject if still unverifiable	Do not present uncertain information as fact.
In scope, current, unique and reliable	Pass	Eligible for analysis with provenance.

Pseudocode (illustrative)

```
for item in collected_items:
    if not authorized_scope.contains(item.target):
        item.status = "REJECT: OUT-OF-SCOPE"
        continue
    if item.is_stale():
        item.status = "RE-CHECK: STALE"
        continue
    if seen_before(normalize(item)):
        item.status = "MERGE: DUPLICATE"
        continue
    if       not       reliable_source(item.source)       or       not
corroborated_if_needed(item):
        item.status = "RE-CHECK: UNVERIFIED"
        continue
    item.status = "PASS: VERIFIED-IN-SCOPE"
    save_with_provenance(item)
```

4.4 Five test sequences and predicted versus observed counts

Counts below are simulated examples for demonstrating the mechanism, not measured live results. “Re-check” includes stale or weakly sourced items that could become valid after confirmation.

Table 17: Validation test sequences

Sequence	Input items	Predicted pass / re-check / reject	Simulated observed result	Notes
1. All-valid	5 current, unique, in-scope, reliable	5 / 0 / 0	5 / 0 / 0	Expected baseline.
2. Out-of-scope	4 valid + 2 outside scope	4 / 0 / 2	4 / 0 / 2	Scope gate rejects early.
3. Stale	3 valid + 2 stale	3 / 2 / 0	3 / 2 / 0	Re-query before use.
4. Duplicated	4 valid + 2 duplicate copies	4 unique / 0 / 0 rejected as unsafe; 2 merged	4 unique / 0 re-check / 0 scope reject; 2 duplicates merged	Duplicates are not separate findings.
5. Mixed	3 valid + 1 stale + 1 duplicate + 1 out-of-scope + 1 weak source	3 / 2 / 1, plus 1 duplicate merged	3 / 2 / 1, plus 1 duplicate merged	Status categories are kept distinct.

4.5 Does validation order matter?

Table 18: Comparison of validation order

Order	Example sequence	Checks on 100 items (illustrative)	Assessment
Order A: reliability → freshness → duplicate → scope	Processes every item through several checks before scope is evaluated.	Up to 400 checks, even when many items are out of scope.	Wastes effort and risks handling out-of-scope data longer than necessary.
Order B: scope → freshness → duplicate → reliability	Out-of-scope items stop at the first check; stale items stop before later checks.	Illustrative: 100 scope checks + 70 freshness + 55 duplicate + 45 reliability = 270 checks.	More efficient; authorization boundary is enforced first.

The counts are a worked example based on hypothetical data, not an empirical benchmark. The key design principle is to put the highest-priority safety gate first. The exact number of later checks depends on how many items survive each stage.

4.6 Scalability from one to fifty targets

Table 19: Illustrative scaling estimate

Targets	Items per target	Total items	Estimated checks using staged validation*	Operational note
1	20	20	54	Manual review can be practical.
5	20	100	270	Use structured records.
10	20	200	540	Deduplication saves repeat work.
25	20	500	1,350	Automate the allow-list and logs.
50	20	1,000	2,700	Batch processing and sampling QA are useful.

*Estimate uses 2.7 checks per input item on average based on the illustrative stage-survival example. Actual effort varies with data quality and validation rules.



Figure 6: Scaling trend (illustrative items)

Real-Time Example: In a penetration test, a third-party hostname may appear in DNS or a search result but not be included in the contract. A scope-first validation gate prevents that hostname from being queried further until written approval is obtained. This is a general contract-control lesson, not a claim about a specific incident.

Evidence Produced: A scope-first validation pipeline, decision table, pseudocode, five test sequences, validation-order comparison and scaling analysis.

Q5 – Evaluate Footprinting of a Hierarchical Organization

5.1 Problem Context

An organization may have a parent domain, subdomains, department systems and third-party services. A systematic traversal records each node and stops at an out-of-scope boundary or a terminal node with no further public data. The hierarchy is a model of authorized public names, not permission to scan every linked provider.

5.2 Hierarchy tree diagram

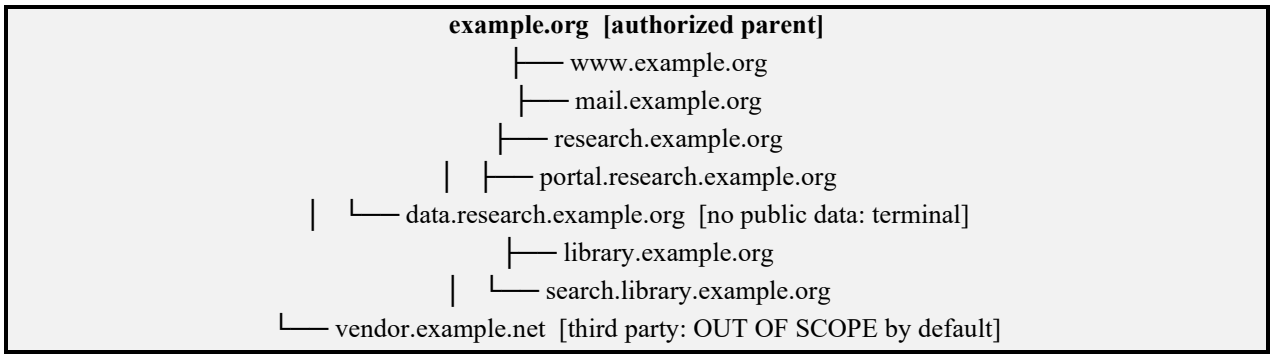


Figure 7: Fictional organization footprint hierarchy

5.3 Systematic traversal and boundary conditions

Breadth-first search (BFS) visits nodes level by level and is easy to audit. Depth-first search (DFS) follows one branch to its end before returning. Either is acceptable if the algorithm logs the node, parent, depth, scope decision, evidence and stop reason. For a readable audit trail, this report uses BFS.

BFS-style pseudocode

```
queue = [authorized_root]
visited = set()
while queue:
    node = queue.pop(0)
    if node in visited:
        continue
    visited.add(node)
    if not in_authorized_scope(node):
        log(node, "STOP: OUT-OF-SCOPE")
        continue
    record_public_evidence(node)
    children = discover_authorized_children(node)
    if not children:
        log(node, "STOP: TERMINAL / NO PUBLIC DATA")
        continue
    for child in children:
        if in_authorized_scope(child):
            queue.append(child)
        else:
            log(child, "STOP: OUT-OF-SCOPE")
```

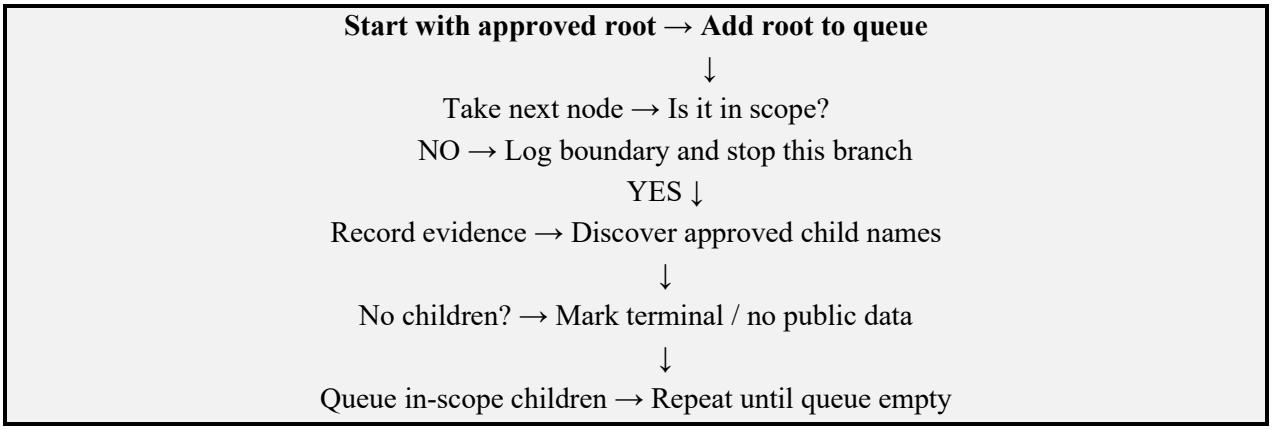


Figure 8: Traversal flowchart

5.4 Three test structures and node counts

Table 20: Traversal test structures

Structure	Example structure	Predicted nodes	Simulated visited nodes	Boundary result
Shallow	root → www, mail, careers	4	4	All in-scope leaves visited.
Deep	root → app → api → v2 → docs	5	5	Depth increases path length but not node count beyond listed nodes.
Irregular	root → www; research → portal/data; library → search; vendor outside scope	7 in-scope nodes + 1 excluded node	7 visited; vendor logged but not traversed	Third-party node is stopped at boundary.

5.5 Prediction versus observation and empty branch

Table 21: Coverage and boundary test

Test	Prediction	Simulated observation	Result
Empty branch	A node with no public children is recorded once and then closed.	data.research.example.org returns no public child data in the lab.	Pass: terminal condition prevents endless traversal.
Out-of-scope child	Third-party vendor is logged but not traversed.	vendor.example.net is tagged OUT-OF-SCOPE.	Pass: boundary respected.
Repeated child / cycle	Already visited node is not processed twice.	Visited-set detects repeated name.	Pass: duplicate traversal avoided.
Deep branch	All authorized nodes are visited until terminal node.	All five nodes on deep path visited.	Pass: complete within declared test tree.

5.6 Systematic traversal versus ad-hoc collection

Table 22: Method comparison

Criterion	Systematic BFS/DFS	Ad-hoc approach
Coverage	Tracks discovered nodes and visited set; gaps are visible.	Can skip branches or repeat the same work.
Scope control	Boundary check occurs at every node.	Analyst may follow an external link accidentally.
Auditability	Parent-child relation and stop reason are logged.	Notes may not explain how a finding was discovered.
Effort	Queue/visited tracking adds setup but scales consistently.	Initially quick for tiny targets, harder to repeat.

Real-Time Example: Subdomain-takeover risks can arise when a DNS record points to an abandoned third-party service. A discovered name is only a lead: verify ownership and service state within the authorized scope, and do not claim or modify an external resource.

Evidence Produced: A hierarchy tree, BFS-style traversal, explicit stop conditions, three test structures, predicted-versus-observed node counts and a systematic/ad-hoc comparison.

Q6 – Evaluate Footprinting Approaches Under Constraints

6.1 Problem Context

An assessment must balance completeness, time, operational impact and detection risk. Passive open-source collection usually makes fewer direct requests to the target, while active DNS/service footprinting can provide fresher direct observations but may create more traffic and require stronger authorization.

6.2 Approach definitions and outputs

Table 23: Two approaches

Approach	Typical steps	Output	Strength / limitation
Passive OSINT	Search public pages, registration data, archived pages and published documents.	Publicly visible facts with source URLs and dates.	Low direct target impact; can be stale or incomplete.
Active DNS footprinting	Query approved A/MX/NS/TXT records and compare responses.	Current resolver-visible DNS data, TTLs and response codes.	More direct and structured; may miss non-DNS information and needs scope controls.

6.3 Workflow diagrams

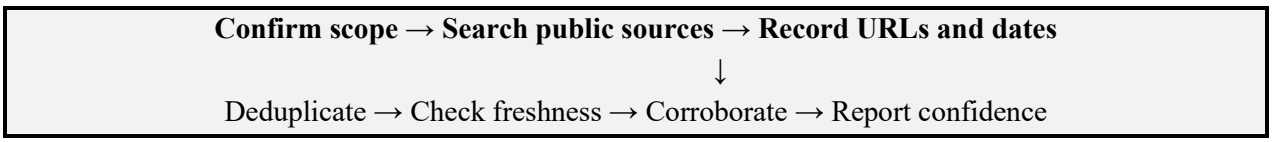


Figure 9: Passive OSINT workflow

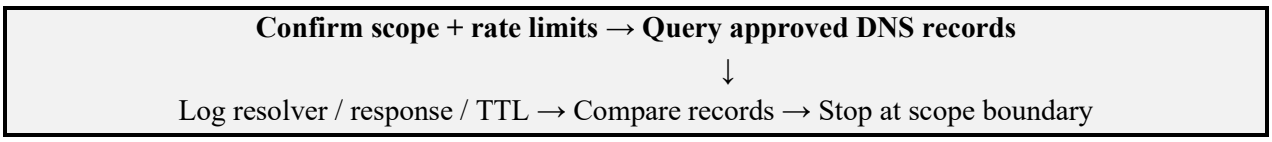


Figure 10: Active DNS workflow

6.4 Increasing scope sizes and effort comparison

The following figures are simulated planning estimates to compare workflows, not benchmark results from real targets. Actual times depend on network, tool configuration, cache state and source responsiveness.

Table 24: Illustrative scope-size comparison

Scope size	Passive steps / estimated time	Active DNS queries / estimated time	Practical interpretation
1 host	8 steps / 3 min	4 queries / <1 min	Both are practical; combine them if useful.
10 hosts	35 steps / 12 min	40 queries / 3 min	Batching makes active DNS efficient.
50 hosts	120 steps / 40 min	200 queries / 10 min	Automation and allow-list checks become important.
500 hosts	900+ steps / 5+ hr	2,000 queries / 1–2 hr at bounded rate	Manual passive review becomes impractical; automate and sample-review.

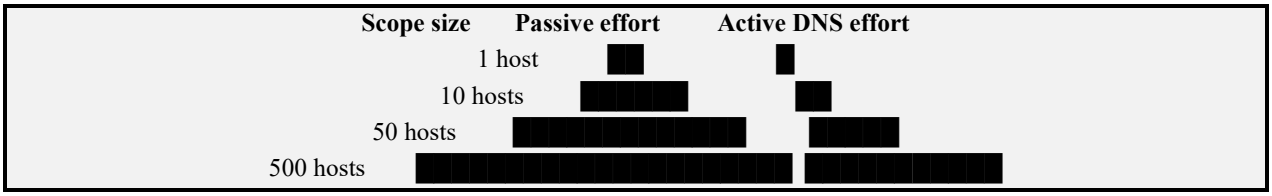


Figure 11: Relative effort trend (illustrative)

6.5 Redundancy and engineering trade-offs

Table 25: Redundancy review

Approach	Common repeated work	Reduction method	Trade-off
Passive OSINT	Same page indexed by several search engines; old and new copies of one PDF.	Canonicalize URLs, hash documents, record dates and deduplicate.	May miss distinct copies that contain useful historical differences.
Active DNS	Repeated queries for identical host/record pairs; cache can make results look identical.	Cache by hostname + record type + timestamp window; preserve TTL and resolver context.	A cache can hide changes if kept too long.

6.6 Is faster or quieter always better?

No. A quiet approach is preferable when minimizing direct interaction is important, but it may provide incomplete or outdated data. Active DNS can validate current resolver-visible information quickly, but only within the approved scope and rate limits. The correct engineering choice depends on the question being answered, authorization, required freshness, target size and potential impact.

Table 26: Recommendation by context

Context	Recommendation	Justification
Small-scope teaching lab	Begin with passive OSINT, then perform a few approved DNS queries.	Students can understand provenance and compare predictions with direct observations.
Large repeated assessment	Use a hybrid, automated workflow: passive collection, scope-gated batched DNS queries, deduplication and structured evidence logs.	Improves repeatability and scale while retaining a human review of exceptions.
Strict low-impact engagement	Prefer passive sources first and request permission before active steps.	Reduces direct target interaction but accepts that some findings may remain unverified.

Real-Time Example: Red-team and penetration-test teams often combine OSINT with carefully scoped active validation. Passive findings can identify leads, while authorized active checks confirm current DNS state. A fast scan is not automatically the best choice if it exceeds scope or creates unnecessary operational impact.

Evidence Produced: Two defined workflows, four increasing scope sizes, simulated effort estimates, redundancy analysis and recommendations for small, large, teaching and repeated engagements.

Q7 – Integrated Review: Diagnose, Redesign and Defend

Selected workflow: Q4 reconnaissance data validation. The baseline design checked source reliability before scope. That ordering can waste work and risks processing data that should have been rejected immediately.

7A. Diagnose the limitation

The bottleneck is poor ordering: items may be checked for freshness, duplication and reliability before the workflow determines whether the target is authorized. This wastes validation effort and increases the time an out-of-scope item remains in the pipeline.

Table 27: Diagnostic evidence (illustrative)

Measure	Original workflow	Observed limitation
Scope check position	Last	Out-of-scope items receive unnecessary processing.
Illustrative checks for 100 items	Up to 400	Each item can pass through four checks.
Scope compliance	Depends on later check	Boundary decision is delayed.

7B. Establish evaluation criteria

Table 28: Evaluation criteria

Criterion	Measurement	Target
Scope compliance	Number of out-of-scope items queried after detection.	Zero.
Coverage	Valid unique items retained / valid unique items supplied.	100% in controlled test set.
Validation effort	Total individual checks performed.	Reduce checks without reducing correct coverage.
Source reliability	Items with traceable source and date.	All passed items have provenance.
Time	Elapsed time in same test environment.	Supporting metric only; not the sole success criterion.

7C. Propose and implement redesign

Redesign order: (1) scope/authorization; (2) freshness; (3) normalization and duplicate detection; (4) source reliability/corroboration; (5) final status and evidence logging. The scope gate is first because it is a safety constraint, not merely a quality check.

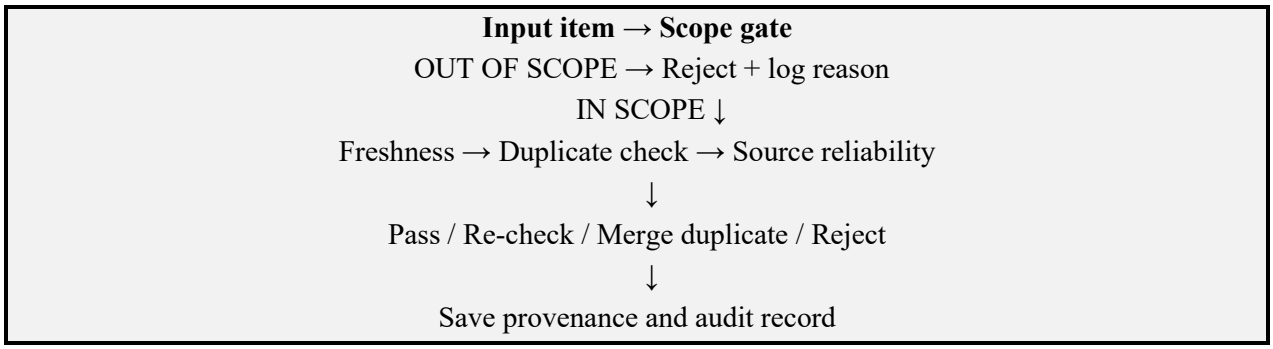


Figure 12: Redesigned validation flow

Trade-off: the redesign requires a maintained allow-list and careful hostname normalization. If the allow-list is incomplete, a valid target may be rejected until the scope owner updates it. This is preferable to silently expanding scope.

7D. Validate and compare

Use the same seven-item mixed test set for both designs. Counts below are simulated, reproducible planning data for illustrating the decision; they are not claimed as measured live performance.

Table 29: Original versus redesigned workflow

Metric	Original order	Redesigned order	Interpretation
Input items	7	7	Same conditions.
Scope checks	7	7	Every item must be checked for scope.
Freshness checks	7	6	One out-of-scope item is rejected before freshness check.
Duplicate checks	6	5	Out-of-scope and stale items do not proceed unnecessarily.
Reliability checks	5	4	Only eligible unique items proceed.
Total checks	25	22	Three checks avoided in this illustrative set.
Valid unique items retained	3	3	No loss of valid coverage.
Out-of-scope items processed beyond scope gate	1 item processed through early checks	0	Redesign enforces boundary earlier.

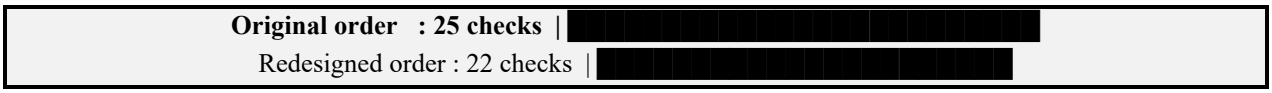


Figure 13: Check-count comparison (simulated)

7E. Defend the final engineering judgment

The redesign meets its primary objective in the controlled example: it retains the same three valid unique items, reduces total checks from 25 to 22, and prevents an out-of-scope item from passing through later checks. The original ordering might still be useful in a non-security data-quality pipeline where scope is not an authorization boundary, but it is not appropriate for reconnaissance work. The final choice is justified by scope compliance and preserved coverage; the small reduction in checks is supporting evidence rather than the main safety argument.

Real-Time Example: A consultant may discover a hostname that belongs to a cloud vendor rather than the contracted customer. A scope-first gate prevents further active testing until the contract owner confirms that the asset is included. This avoids turning a useful lead into unauthorized activity.

Evidence Produced: A diagnosed bottleneck, measurable criteria, redesigned validation order, equivalent test comparison and evidence-based final engineering judgment.